

Security & Scalability Architecture Report

Systems Engineering Team

February 21, 2026

1 Introduction

This document outlines strategic solutions for modern security challenges and provides a foundational understanding of system scalability, specifically addressing authentication security, signal integrity for IoT devices, and infrastructure growth.

2 Authentication Without Key Storage

Storing raw encryption keys in a database creates a “single point of failure.” If the database is compromised, all data is decrypted. To avoid storing a copy of the key while maintaining the ability to authenticate, we utilize **Key Derivation** and **Hardware Abstraction**.

2.1 Solution: Key Derivation Functions (KDF)

Instead of storing the key, the system stores a **Salt** and a **Cryptographic Hash**.

- **Process:** When a user attempts to authenticate, they provide a passphrase. The system applies a KDF (like Argon2 or PBKDF2) to the passphrase + salt to “re-derive” the encryption key in volatile memory (RAM).
- **Verification:** The system compares the result against the stored hash. If they match, the key is used for the current session and then immediately purged from memory.
- **Result:** The database never contains the key, only the “proof” required to recreate it.

2.2 Solution: Hardware Security Modules (HSM)

For enterprise-grade security, we use “Enveloping”:

- A **Master Key** is stored inside a physical or virtual HSM that cannot be exported.
- The database stores a **Data Encryption Key (DEK)** that is itself encrypted by the Master Key.
- To decrypt data, the application sends the encrypted DEK to the HSM, which returns the usable key to memory only.

3 Information Flow: Securing the “Unlock” Signal

Smart glasses and IoT devices communicating via Bluetooth or Wi-Fi are vulnerable to “packet sniffing” and “replay attacks” because radio waves are broadcasted publicly.

3.1 Defensive Measures

- **End-to-End Encryption (E2EE):** We implement a TLS-like handshake between the glasses and the receiver. Even if the signal is captured mid-air, the payload is encrypted with a session-specific key that the attacker does not possess.
- **Rolling Codes / TOTP:** The “unlock” signal is never the same twice. Using Time-based One-Time Passwords (TOTP), the glasses generate a code that is only valid for 30 seconds. A hijacked signal becomes useless the moment it is intercepted.
- **Mutual Authentication:** Before the signal is sent, the receiver must prove its identity to the glasses (and vice versa) using digital certificates. This prevents “Man-in-the-Middle” attacks where a hacker mimics the receiving device.

4 Explaining Scalability

Scalability is the architectural property that allows a system to handle increased load (users, data, or transactions) without a proportional increase in latency or cost.

4.1 Dimensions of Scaling

1. Vertical Scaling (Scaling Up):

- **Definition:** Increasing the capacity of a single resource (e.g., adding more RAM or a faster CPU to a server).
- **Pros:** Simple to implement; no changes to application logic.
- **Cons:** Hard hardware limits; creates a single point of failure; becomes exponentially expensive.

2. Horizontal Scaling (Scaling Out):

- **Definition:** Adding more units to the pool of resources (e.g., adding ten small servers instead of one giant one).
- **Pros:** Theoretically infinite growth; provides high availability.
- **Cons:** Requires a Load Balancer and “stateless” application design.

4.2 Key Scalability Concepts

- **Load Balancing:** A gateway that distributes incoming traffic across multiple servers.
- **Database Sharding:** Breaking a large database into smaller pieces (shards) across different servers based on a key (e.g., User ID).
- **Caching:** Using in-memory stores like Redis to keep frequently accessed data close to the application.
- **Statelessness:** Designing the app so that any server can handle any request, with session data stored in a shared cache.